

L2 - 8.4. Threat Hunting: Endgame

Task 1 - Introduction

Detecting and hunting for actions on objectives, such as data exfiltration, disruption, or destruction, is the final line of defense to stop attackers from causing irreversible damage after they have already breached, escalated, and moved laterally across your network.

Task 2 - Understanding Actions on Objectives

Understanding the Actions on Objectives phase—the final stage of the Cyber Kill Chain where threat actors carry out their ultimate goals after securing network access—provides the essential foundational context needed to hunt for and identify critical indicators of compromise in real-world log data.

Common Attacker Objectives: Understanding what attackers are trying to achieve helps you identify and hunt their final actions. Common objectives include:

- **Data exfiltration:** Stealing sensitive data such as financial records, intellectual property, trade secrets, and personally identifiable information (PII).
- **Data destruction:** Permanently deleting or corrupting critical data to disrupt business operations.
- **System disruption:** Disabling services, corrupting recovery mechanisms, and rendering systems inoperable.
- **Encryption for ransom:** Encrypting critical data and demanding payment for decryption keys.
- **Data manipulation:** Altering data to cover tracks, manipulate records, or cause indirect harm.

Why Hunting Actions on Objectives Matters: Hunting for threats during the Actions on Objectives phase is crucial to drastically reduce dwell time and intercept attackers before they can inflict imminent, high-impact damage on the organization.

MITRE ATT&CK and Actions on Objectives: In this room, we focus on three MITRE ATT&CK tactics that are commonly used during the Actions on Objectives phase:

- [Collection \(TA0009\)\(opens in new tab\)](#): Gathering data before exfiltration, such as credential harvesting and surveillance.
- [Exfiltration \(TA0010\)\(opens in new tab\)](#): Stealing collected data from the target system and sending it to attacker-controlled infrastructure.
- [Impact \(TA0040\)\(opens in new tab\)](#): Destroying, disrupting, or manipulating data and systems to accomplish the attacker's final goal.

These three tactics represent the attacker's endgame. By hunting for indicators of these activities, you can detect and stop attackers before they accomplish their objectives.

Hunting Approach for This Room: In this room, we will hunt for real-world examples of each tactic using actual Windows logs and system artefacts. Each case demonstrates how attackers implement these techniques using both legitimate system tools and malicious scripts. You will learn to recognise suspicious patterns, correlate events, and identify the attacker's true objectives by examining the evidence they leave behind in the logs.

Answer the questions below

What is the term used for the adversary's lifetime in the network?

Dwell Time

Task 3 - Lab Setup

The main data sources we will use include:

- **Windows Security logs:** Contains authentication events, process execution details, registry modifications, and file operations.
- **Sysmon logs:** Provides detailed system activity including process creation, network connections, file access, and registry modifications.
- **Windows PowerShell logs:** Records PowerShell script execution and command-line activities.
- **PowerShell Operational logs:** Contains operational details about PowerShell script block execution.
- **System logs:** Contains system-level events such as service startup, shutdown, and critical system operations.

Hunt Scenarios and Indices: This room contains three distinct hunt scenarios, each focused on a different tactic within the Actions on Objectives phase:

- **Case Collection** ([Index: case_collection](#)): Hunt for keylogger activity and data gathering techniques. Available log sources include Security, Sysmon, Windows PowerShell, and PowerShell Operational logs.
- **Case Exfiltration** ([Index: case_exfiltration](#)): Hunt for data exfiltration over ICMP protocol. Available log sources include Security, Sysmon, Windows PowerShell, and PowerShell Operational logs.
- **Case Impact** ([Index: case_impact](#)): Hunt for data destruction and system disruption activities. Available log sources include Security, Sysmon, System, Windows PowerShell, and PowerShell Operational logs.

Task 4 - Tactic: Collection

The Collection tactic (TA0009)([opens in new tab](#)) encompasses techniques used by adversaries to gather valuable data from the target system that supports their objectives. The specific data targeted varies based on the attacker's goals. Adversaries commonly seek data that can be used for exploitation, pivoting, intelligence gathering, or monetisation. Target data includes confidential records, financial information, intellectual property, and personally identifiable information (PII).

Common collection techniques include:

- Man-in-the-middle attacks
- ARP/LLMNR poisoning
- SMB relay
- DHCP spoofing
- Traffic dumps
- Keylogging
- Input capture
- Data collection from local systems, cloud repositories, or network shares

The Link-Local Multicast Name Resolution (LLMNR) is a protocol based on the Domain Name System (DNS) packet format that allows both IPv4 and IPv6 hosts to perform name resolution for hosts on the same local link.

Server Message Block (SMB) is a communication protocol originally developed in 1983 by Barry A. Feigenbaum at IBM and intended to provide shared access to files and printers across nodes on a network of systems running IBM's OS/2. It also provides an authenticated inter-process communication (IPC) mechanism.

In this task, we will hunt for one common collection scenario: keylogging activity.

Hunting Keylogging: This hunt focuses on detecting keylogger activity triggered by an abused administrative account or an attacker with administrative access. This investigation focuses specifically on the keylogging activity itself, not the pre or post-compromise activities.

Keyloggers record keyboard activities. Common implementations use direct API calls, registry modifications, malicious driver files, customised scripts, function calls, or packed executables. While modern security tools detect

many keylogger patterns, manual hunting skills are vital for detecting sophisticated implementations.

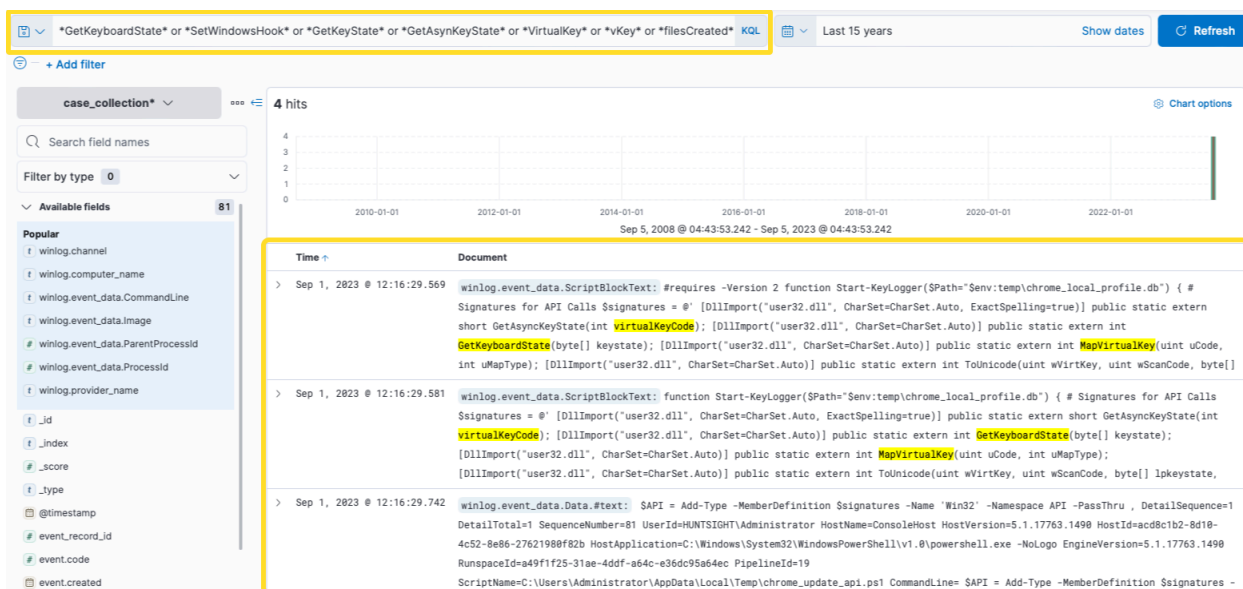
In this case, we hunt for API-based keylogging. Common Windows API calls used for keylogging include `GetKeyboardState`, `SetWindowsHook`, `GetKeyState`, `GetAsyncKeyState`, `VirtualKey`, `vKey`, `filesCreated`, and `DrawText`. Low-level hook techniques include `SetWindowHookEx`, `WH_KEYBOARD`, `WH_KEYBOARD_LL`, `WH_MOUSE_LL`, and `WH_GETMESSAGE`.

We will use the `case_collection` index to hunt for key logging activity on September 1, 2023.

We will use overall search insights on process executions and pattern matches. Our hypothesis is clear: we are looking for keylogging actions matching known patterns. Using the Discover tab, search if available log files contain matches using the following KQL query:

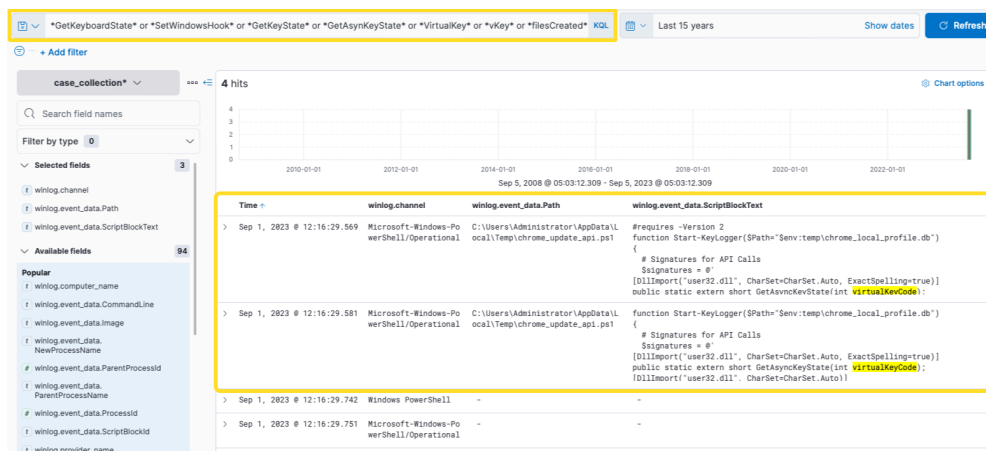
```
GetKeyboardState* or *SetWindowsHook* or *GetKeyState* or *GetAsyncKeyState* or *VirtualKey* or *vKey* or *filesCreated* or DrawText
```

Sort the timestamp in ascending order to view the sequence of executions from earliest to latest.



The results show multiple pattern matches in the index. The main visibility comes from the Microsoft-Windows-PowerShell/Operational log file. Add the following columns to increase visibility:

- `winlog.channel`
- `winlog.event_data.Path`
- `winlog.event_data.ScriptBlockText`

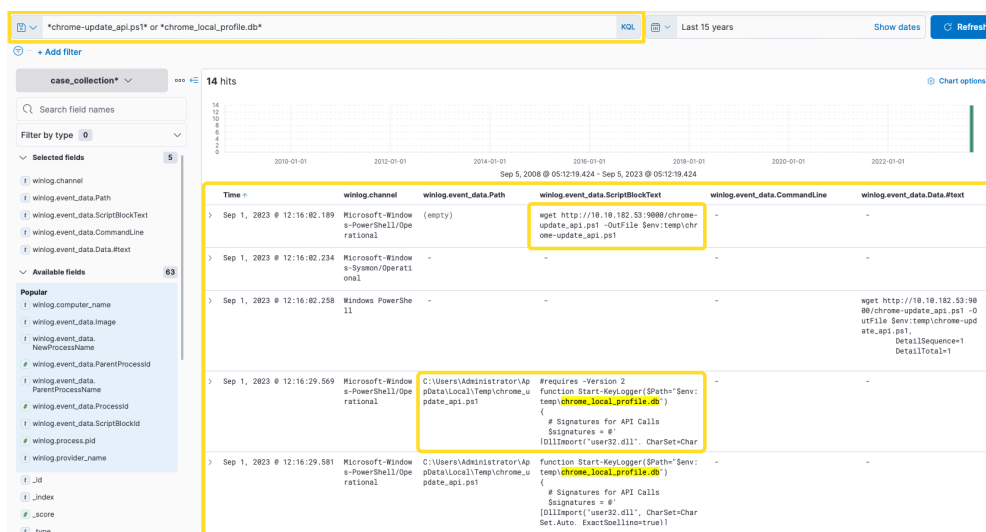


We now have a suspicious file name and executed code block which references another suspicious file. Let's dig deeper by searching for both files using the following query:

`chrome-update_api.ps1* or *chrome_local_profile.db*`

Set the following columns to increase visibility:

- winlog.channel
- winlog.event_data.Path
- winlog.event_data.ScriptBlockText
- winlog.event_data.CommandLine
- winlog.event_data.Data.#text



The results show the suspicious PowerShell file was downloaded using wget and executed. The executed script reveals that the second suspicious file is the keylogger's database. Let's dig deeper to examine the database file using the following query:

`winlog.event_data.ScriptBlockText : "*chrome_local_profile.db"`

Update the column filters to:

- winlog.event_data.Path
- winlog.event_data.ScriptBlockText
- winlog.event_data.Payload

The screenshot shows the Splunk search results for the query `winlog.event_data.ScriptBlockText: "chrome_local_profile.db"`. The left sidebar displays the 'case_collection' filter and a list of available fields. The main results pane shows three hits. The first hit is expanded, showing a PowerShell script that uses the `cat` command to view the contents of `chrome_local_profile.db`.

The results show details about the database file. The `cat` command is used to view file contents, allowing us to see the logged keystrokes. At this point, you could correlate parent-child process relationships and examine events chronologically using the View surrounding documents option.

Required steps:

- Click the upper left arrow to expand the log event details.
- Click on the View surrounding documents link.

The screenshot shows the 'Expanded document' view in Splunk. The document is titled `Sep 1, 2023 @ 12:21:31.646 (empty)`. The `cat .\chrome_local_profile.db` command is visible. A yellow arrow points from the `View surrounding documents` link to the 'Expanded document' view.

This creates a chronological list of events. Click Load 5 newer documents to follow events after the `cat` command execution. The event you clicked will be highlighted in light blue as your starting point.

The screenshot shows the 'Surrounding documents' view in Splunk. The documents are listed in a table with columns for Time, winlog.event_data.Path, winlog.event_data.ScriptBlockText, and winlog.event_data.Payload. The document `Sep 1, 2023 @ 12:21:31.646 (empty)` is highlighted in light blue. A yellow arrow points from the `Load 5 newer documents` button to the highlighted document.

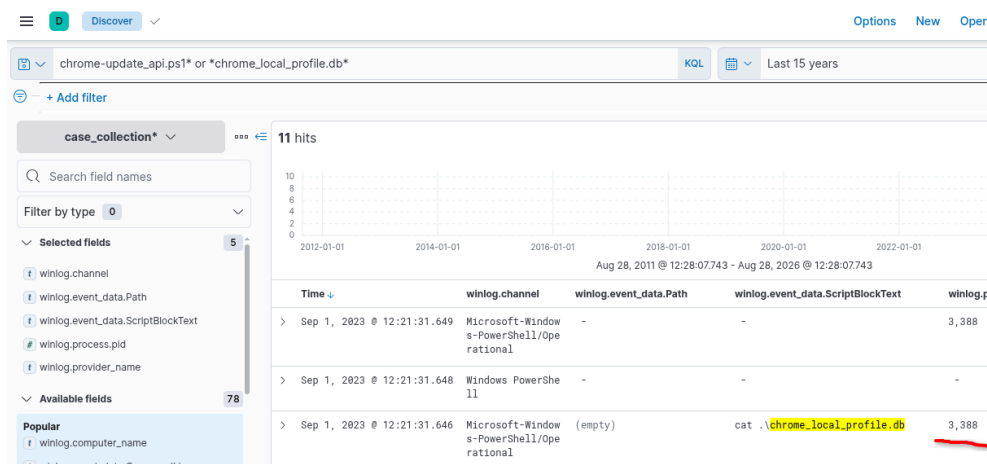
Since command output is not redirected to a file, we focused on the executed command, timing, and payload details. Now the keylogger database contents are fully visible. PowerShell initiated a process that downloaded a malicious script from a remote host, which logged keystrokes and created a database file.

As a threat hunter, there are several areas you could investigate further to deepen this hunt. File creation activities could reveal when and how the malicious PowerShell script was created. Process relationships could expose the starting point of the attacker's activity. Function calls could determine if the attacker opened or transferred the dump database.

Answer the questions below

What is the Process ID of the process that downloads the malicious script?

3388



What is the logged mail account?

hunted-victim2323@gmail.com

Documents surrounding #289aa198ccfc15e34f403820ecf27843124115e8

Time	winlog.channel	winlog.event_data.Path	winlog.event_data.ScriptBlockText	winlog.event_data.Payload
Sep 1, 2023 @ 12:21:31.654	Microsoft-Windows-PowerShell/Operational	-	-	CommandInvocation(Set-StrictMode): "Set-StrictMode" ParameterBinding(Set-StrictMode): name="Off"; value="True"
Sep 1, 2023 @ 12:21:31.653	Microsoft-Windows-PowerShell/Operational	-	-	-
Sep 1, 2023 @ 12:21:31.652	Microsoft-Windows-PowerShell/Operational	-	-	-
Sep 1, 2023 @ 12:21:31.652	Microsoft-Windows-PowerShell/Operational	-	-	-
Sep 1, 2023 @ 12:21:31.651	Microsoft-Windows-PowerShell/Operational	(empty)	prompt	-
Sep 1, 2023 @ 12:21:31.651	Microsoft-Windows-PowerShell/Operational	-	-	-
Sep 1, 2023 @ 12:21:31.651	Microsoft-Windows-PowerShell/Operational	-	-	-
Sep 1, 2023 @ 12:21:31.650	Microsoft-Windows-PowerShell/Operational	-	-	CommandInvocation(Out-Default): "Out-Default" ParameterBinding(Out-Default): name="InputObject"; value="how to open incognito tab" ParameterBinding(Out-Default): name="InputObject"; value="gmail" ParameterBinding(Out-Default): name="InputObject"; value="hunted-victim2323@gmail.com" ParameterBinding(Out-Default): name="InputObject"; value="hunted-victim2323@gmail.com"

Task 5 - Tactic: Exfiltration

The Exfiltration tactic (TA0010) ([opens in new tab](#)) encompasses techniques used by adversaries to steal or leak data from the target system or network. The primary goal of this tactic is to extract data while avoiding detection. Compression and encryption are often used to gather maximum data and minimise detection risk.

Common exfiltration techniques include:

- Traffic duplication
- Data transfer over alternative protocols
- Data transfer over encrypted or unencrypted command and control channels
- Exfiltration over web services and cloud storage mediums
- Exfiltration over Bluetooth and portable devices
- Sending data to command and control servers or channels
- Sending data through alternative channels with size-limited transmissions

The techniques shown here are some examples. Exfiltration techniques may be triggered by automation or scheduled jobs. Understanding exfiltration activities is critical because they represent confirmed data loss and breach. Hunting this tactic requires understanding how adversaries use system tools and custom scripts to move data out of your network. Effective defence against exfiltration involves data classification and access controls, continuous monitoring with data loss prevention (DLP) solutions, and encryption of sensitive data. In this task, we will hunt for one common exfiltration scenario: data exfiltration over ICMP.

Hunting Data Exfiltration over ICMP

This hunt demonstrates detecting data exfiltration over ICMP protocol. The scenario focuses on hunting data exfiltration over the ICMP traffic channel while examining Windows artefacts at the system and process level. This provides insight into the changes that occur during data exfiltration activity.

Adversaries use various procedures for data exfiltration. They typically use system native tools or custom command and control channels with controlled size limits to transmit data. Some adversaries implement two-stage exfiltration, first transferring data to an alternative network location over an unencrypted protocol, then transferring to a dedicated encrypted command and control channel. Understanding system-level processes and scripted actions is vital for detecting these activities.

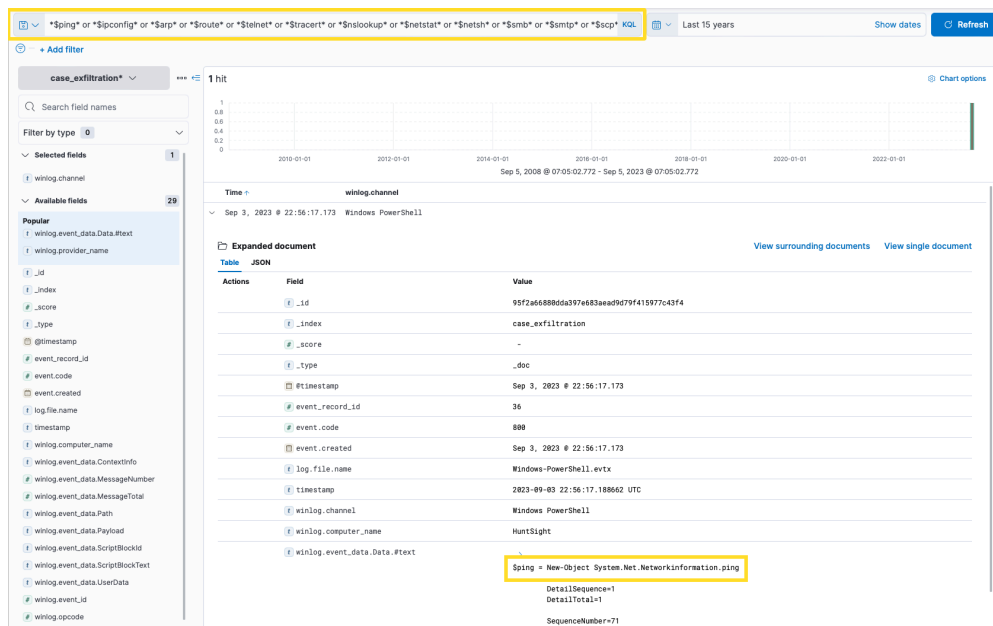
Common data exfiltration tools and techniques include scripting with system utilities such

as `ping`, `ipconfig`, `arp`, `route`, `telnet`, `tracert`, `nslookup`, `netstat`, `netsh`, `smb`, `smtp`, `scp`, `ssh`, `wget`, `curl`, `certutil`, `net use`, `nc`, `ncat`, `netcut`, `socat`, `dnscat`, `ngrok`, `psfile`, `psping`, `tcpvcon`, `tftp`, `socks`, and `Invoke-WebRequest`.

We will use the `case_exfiltration` index to hunt for data exfiltration on September 3, 2023.

We will use overall search insights on process executions and pattern matches. Our hypothesis is clear: we are looking for system tool calls that lead to data transfer. Using the Discover tab, search if available log files contain matches using the following KQL query:

```
$ping* or *$ipconfig* or *$arp* or *$route* or *$telnet* or *$tracert* or *$nslookup* or
*$netstat* or *$netsh* or *$smb* or *$smtp* or *$scp* or *$ssh* or *$wget* or *$curl*
or *$certutil* or *$nc* or *$ncat* or *$netcut* or *$socat* or *$dnscat* or *$ngrok* or
*$psfile* or *$psping* or *$tcpvcon* or *$tftp* or *$socks* or *$Invoke-WebRequest* or
*$server* or *$post* or *$ssl* or *$encod* or *$chunk*
```



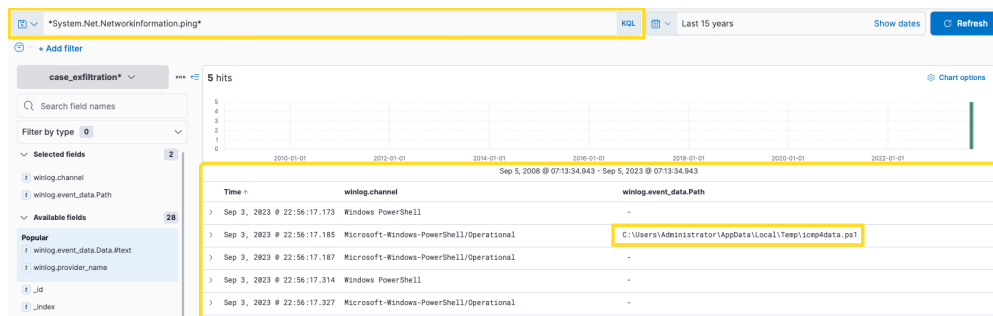
We found one match. Let's continue hunting with the detected system call. Run the following query:

```
System.Net.NetworkInformation.Ping*
```

Sort the timestamp in ascending order to view the sequence of executions from earliest to latest.

Filter the following column to reveal if any executable file is involved in the suspicious activity:

- winlog.event_data.Path

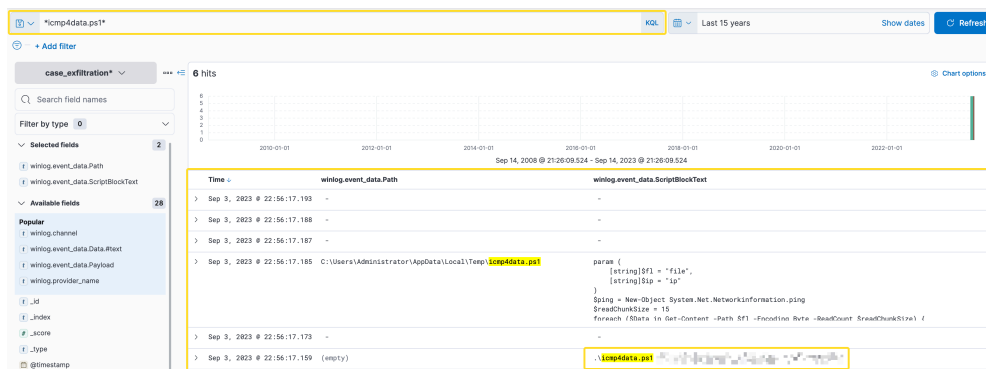


The result shows a suspicious PowerShell script transferring files using ICMP packets, indicating a data exfiltration script. Let's run the following query to see all associated activity:

```
icmp4data.ps1*
```

Update the column filters to increase visibility:

- winlog.event_data.Path
- winlog.event_data.ScriptBlockText



The query results identify the exfiltrating script, the exfiltrated file, and the upload server. The discovered script is used for exfiltrating data over ICMP protocol. Unlike collection activities, no prior indicator of downloading the exfiltration script exists, meaning it was likely created by the adversary or planted through a different technique.

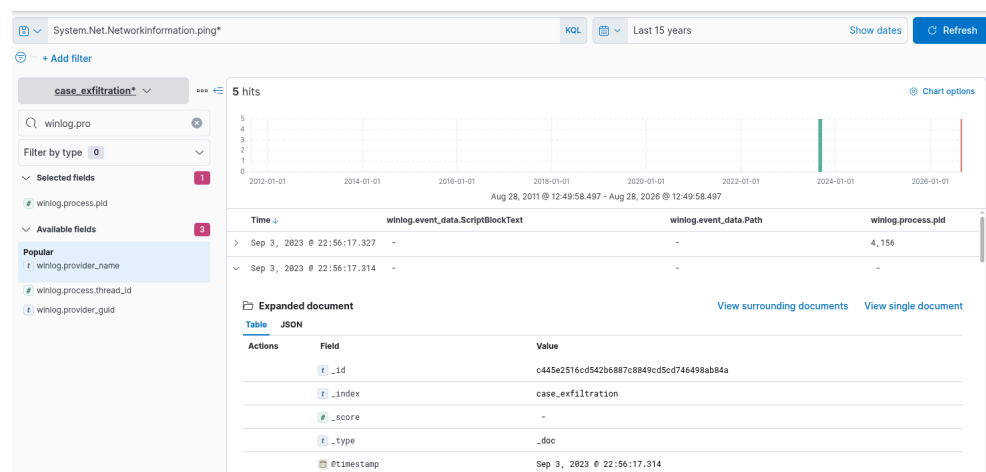
This is one approach to hunting data exfiltration using system native tools over unencrypted channels. You should investigate the query results further to deepen your findings and understand how the script works and which data was exfiltrated.

As a threat hunter, there are several areas you could investigate further. Exfiltration script analysis would reveal how the script operates. Tracking the exfiltration destination would show where data is being sent. Identifying connections made to the exfiltration destination would map the attacker's infrastructure. While we will not explore these aspects in this room, understanding these possible next steps is crucial for conducting comprehensive threat hunting investigations.

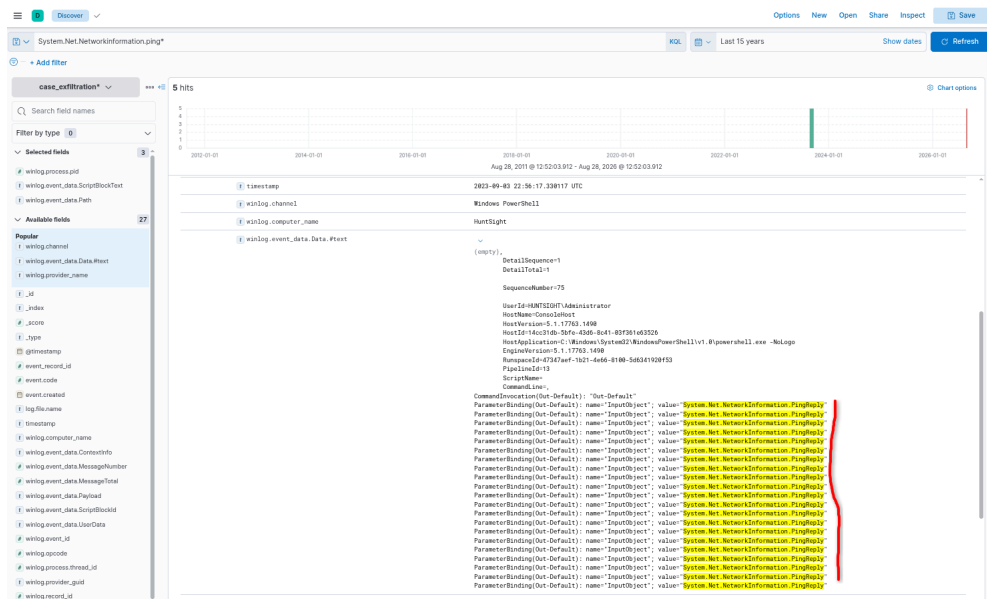
Answer the questions below

What is the total number of sent ICMP packets?

21

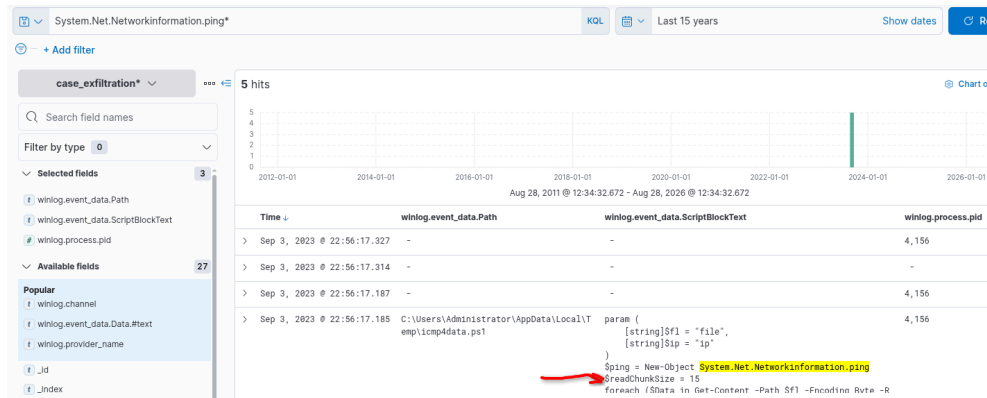


In the expanded document, winlog.event_data.Data.#text section



How many bytes (chunk) is the amount of data carried in each packet?

15

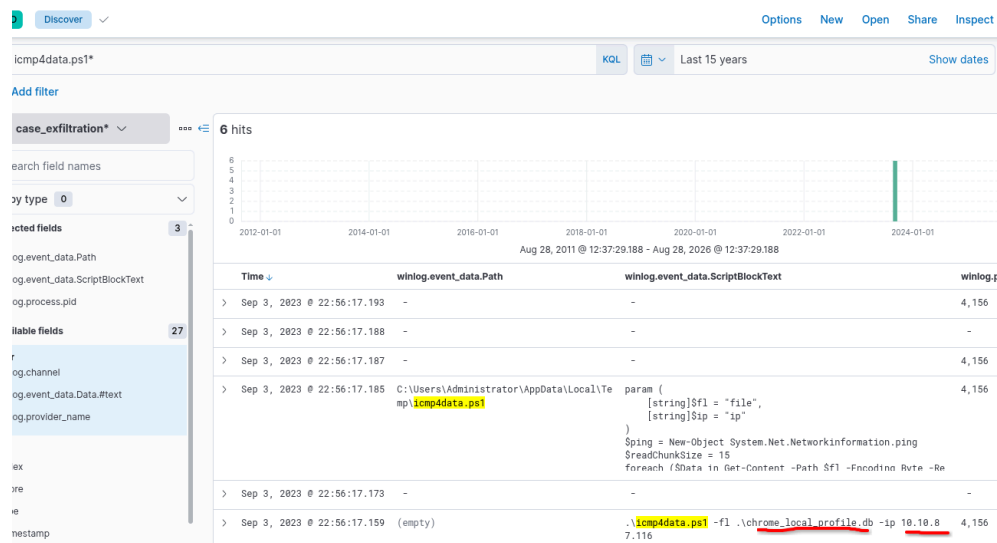


What is the name of the exfiltrated document?

chrome_local_profile.db

What is the server's IP address (defanged) where the exfiltrated document is sent?

10[.]10[.]87[.]116



Task 6 - Tactic: Impact

The **Impact tactic (TA0040)** ([opens in new tab](#)) encompasses techniques used by adversaries to disrupt availability, hinder expected functionality, and compromise integrity through data destruction, disruption, or manipulation. Since each adversary has different purposes, threat hunters must consider numerous possibilities affecting valuable data and system resources. Adversaries sometimes alter data while making processes appear normal during exploitation, making impact hunting challenging. Finding suspicious activities requires excellent attention to detail.

Common impact techniques include:

- Ransomware
- File destruction and removal
- Data manipulation
- Account manipulation
- Access manipulation
- Network configuration changes
- Data destruction, disruption, and manipulation
- Data encryption
- Defacement
- Service destruction

The techniques shown here are some examples. Impact activities represent the consequences of successful attacks. Understanding this phase is vital for detecting weaknesses, enhancing detection and prevention capabilities, and mitigating risks. Adversaries often use native system utilities to evade security products while remaining undetected. While ransomware is commonly associated with impact, indirect long-term system disruption goals may be less visible but equally damaging. Effective defence requires regular risk assessments, threat hunting and penetration testing, in-depth hardening with zero-trust models, improved visibility and monitoring, and prepared incident response and disaster recovery plans. In this task, we will hunt for one common impact scenario: data disruption and system recovery manipulation.

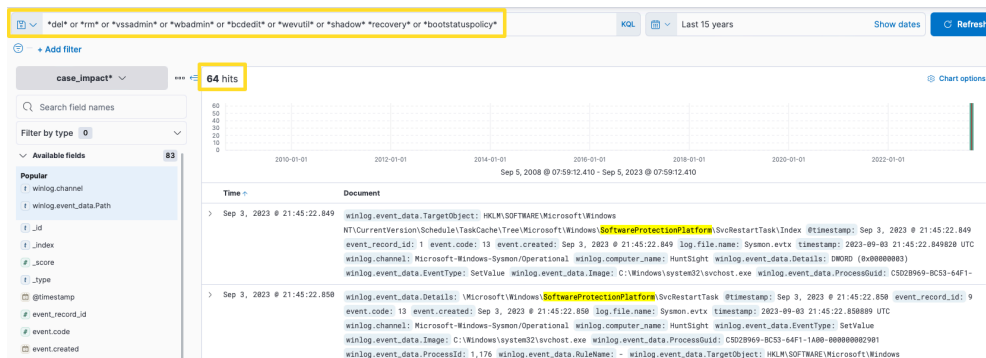
Hunting Data Disruption and Recovery Manipulation: This hunt demonstrates detecting data destruction and recovery manipulation over native system processes. The scenario focuses on hunting shadow backup removal and system recovery point corruption, similar to techniques used by the Olympic Destroyer APT group. Adversaries use

various procedures for implementing system disruption and manipulation. Typically, they use native system utilities to evade security detection. There are several approaches to this attack, including two-stage procedures where adversaries first corrupt recovery mechanisms then perform destructive actions. Understanding system-level processes and scripted actions is vital for detecting these activities. Common data disruption tools and techniques include scripting with system utilities such as `del`, `rm`, `vssadmin`, `wbadmin`, `bcdedit`, `wevutil`, `shadow`, `recovery`, and `bootstatuspolicy` commands.

We will use the `case_impact` index to hunt for data destruction and recovery manipulation on September 3, 2023. We will use overall search insights on process executions and pattern matches. Our hypothesis is clear: we are looking for system tool calls that lead to system disruption and data manipulation. Using the Discover tab, search if available log files contain matches using the following KQL query:

```
del* or *rm* or *vssadmin* or *wbadmin* or *bcdedit* or *wevutil* or *shadow* or *recovery* or *bootstatuspolicy*
```

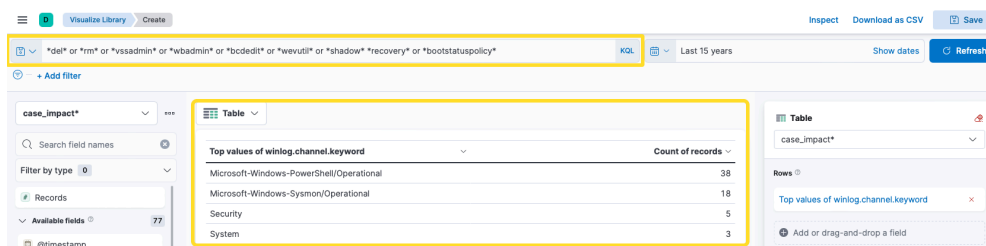
Sort the timestamp in ascending order to view the sequence of executions from earliest to latest.



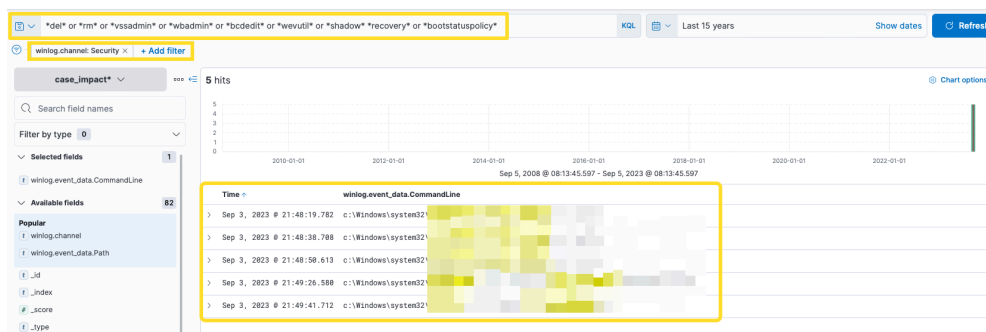
The results are challenging to interpret. Let's visualise by log sources to decide where to focus. Click on the following field and choose the Visualize option:

- winlog.channel

Then select the table format.



Since we are looking for system native tools, the Security log could provide the most relevant results. Let's return to the Discover tab and add `winlog.channel: Security` as a log source filter and add the field `winlog.event_data.CommandLine` as a column.

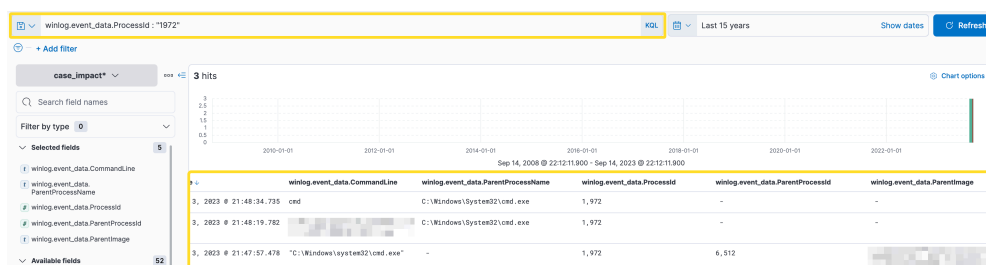


The time field helps highlight the first command executed. However, we still need to identify the actual starting point. Remove the winlog.channel filter, and let's focus on the first suspicious event by filtering on the ProcessId:

```
winlog.event_data.ProcessId : "1972"
```

Update the column filters to increase visibility:

- winlog.event_data.CommandLine
- winlog.event_data.ParentProcessName
- winlog.event_data.ProcessId
- winlog.event_data.ParentProcessId
- winlog.event_data.ParentImage



This query provides clear results to explore and correlate parent-child process relationships. The parent process is now visible with all nested details. The revealed actions target system disruption by removing shadow copies and destroying system recovery points and services.

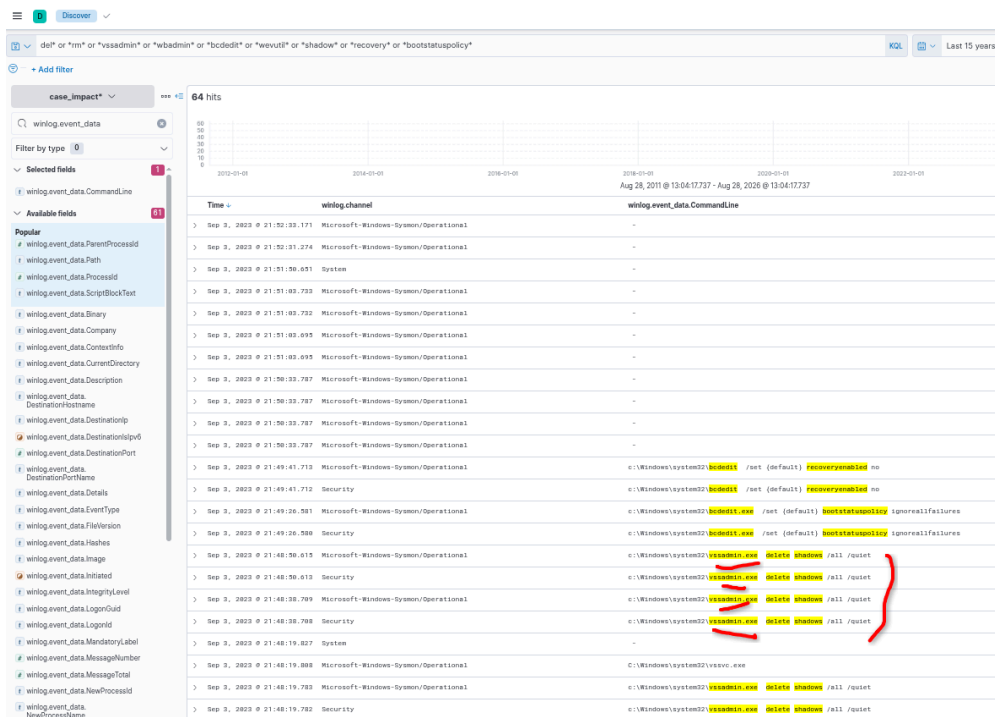
This is one approach to hunting system data manipulation using native system tools and utilities. You should investigate the query results further to deepen and enrich your findings.

As a threat hunter, there are several areas you could investigate further. Discovering the primary process that launched subprocesses would reveal the orchestration of adversary actions. Identifying chained PowerShell and command shell executions would map the attack sequence. While we will not explore these aspects in this room, understanding these possible next steps is crucial for conducting comprehensive threat hunting investigations.

Answer the questions below

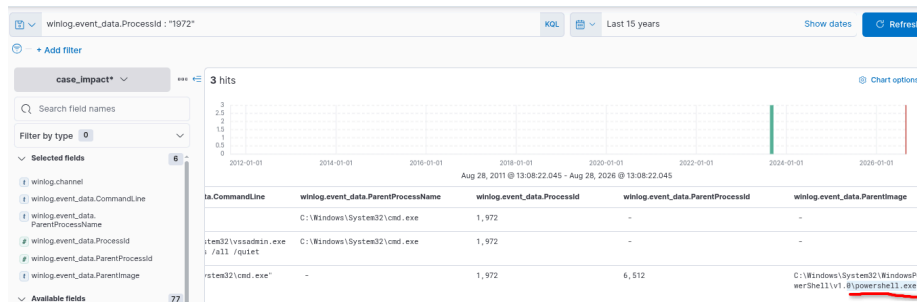
What is the name of the system executable used to remove shadow copies?

vssadmin.exe



What is the main shell image that started the attack chain?

powershell.exe



What is the process ID that started the attack chain?

6512

Task 7 - Conclusion

- Gain hands-on threat hunting investigation skills in real-world scenarios
- Understand the **Actions on Objectives** phase and its significance in the Cyber Kill Chain
- Correlate and evaluate artefacts to develop and test threat hunting hypotheses
- Hunt for collection, exfiltration, and impact activities using MITRE ATT&CK techniques
- Identify attacker objectives and the techniques used to accomplish them